RSS Digest
Generated at: 2026-10-22 13:49:47

1. Widespread PHP Flaw May Cause Many Site Outages Today
Source: Krebs on Security | Published: Wed, 21 Oct 2026 15:26:07 +0000
Link:
https://krebsonsecurity.com/2026/10/widespread-php-flaw-may-cause-many-site-outages-today/
Expect to see quite a few websites serving "404" or "Page Not Found" errors today: Nearly 70 percent of websites need to update their core software to fix a pair of vulnerabilities that allow an attacker to seize full control over affected servers. Experts say there are working exploits for the flaws, and that these critical bugs are already being exploited in the wild.

2. Upgrade your PHP installs immediately to protect against php2shell
Source: Jeff Geerling | Published: Wed, 21 Oct 2026 10:10:00 -0400
Link: https://www.jeffgeerling.com/blog/2026/php-vulnerability-php2shell/
This morning, two critical PHP Security Advisories were published: RCE via OOM corruption (9.2/10) RCE via stale global state (9.2/10) If you’re running PHP for any service, you need to upgrade immediately to 8.2.35, 8.3.36, 8.4.27, or 8.5.12. And if you use Remi’s repos on RedHat-derivative Linux distros, you need to switch to official repos temporarily as Remi’s on vacation and can’t update his community repo. (Reminds me of xkcd 2347). Remi pushed updates even while on vacation !

3. Today’s PHP Security Release, and How We’re Strengthening PHP Security
Source: Simon Willison’s Weblog | Published: 2026-10-21T18:41:53+00:00
Link: https://simonwillison.net/2026/Oct/21/php-security-release/
Today’s PHP Security Release, and How We’re Strengthening PHP Security If you’re running anything on PHP it’s vital you upgrade - today’s updates (across the entire PHP 8.x line) address two remote code execution holes, and there have been exploits circulating since last night, thanks to a leak in the coordinated disclosure process. This post from the PHP Foundation explain what went so wrong: On Tuesday, October 20th, at around 15:00 UTC, the two CVE IDs began circulating on online forums and social media. They came with a wrong release time and a wrong CVSS score of 10.0 (the actual score is 9.2). No technical details leaked. In response, the PHP project brought its pre-announcement forward and published it at 19:30 UTC . It also moved the release from October 22nd, 14:00 UTC, to October 21st, 14:00 UTC [...] As a result of the leak and pre-announcement around 20:00 UTC, Calif, one of the security firms that had reported the issues mistakenly published a video. It showed their proof of concept working against a number of targets and revealed a few additional, though limited, details about the vulnerabilities. Copies of the deleted video started circulating on social media soon a...

4. Panache ? RTS Belle Époque pour mobile
Source: Simon Willison’s Weblog | Published: 2026-10-21T16:25:16+00:00
Link: https://simonwillison.net/2026/Oct/21/panache/
Panache ? RTS Belle Époque pour mobile Well this is delightful: I released Battle Drones yesterday under an Apache 2.0 License and there’s already a French language fork which reskins the game to take place in steampunk 1900s France and adds an animated intro! Panache est un jeu de stratØgie en temps rØel pour mobile et navigateur, dans la France de la Belle Époque (vers 1900) : dirigeables, Fardiers àvapeur, Creusot cuirassØs, automates en kØpi, Gargantua la forteresse marchante ? et beaucoup de panache. You can play Panache here - it’s worth clicking that link just to experience the new intro video. So far it’s mostly just aesthetic updates as opposed to gameplay changes. The music has had a French twist added to it as well. The new steampunk models are so cool! Here’s a page with the original Battle Drones models and that same page with the new Panache alternatives . This is a comparison of the original and the new design for the Goliath: Via @Meffysto69 Tags: game-design , open-source

5. sparqlite: SPARQL 1.1 inside SQLite, written in Rust

Source: Simon Willison’s Weblog | Published: 2026-10-16T01:58:00+00:00
Link: https://simonwillison.net/2026/Oct/16/sqlite-sparql-rust/
Research: sparqlite: SPARQL 1.1 inside SQLite, written in Rust This research task is really an experiment in running Claude Code for web in "Ultracode" mode, as described in Orchestrate subagents at scale with dynamic workflows in the Claude Code documentation. With Ultracode turned on, Claude Code makes aggressive use of dynamic workflows - it generates JavaScript that defines and coordinates a network of subagents to take on complex problems. My initial prompt was this - I meant "hit the rows directly", the word "delete" was an accidental typo on my phone: Write a SQLite extension in Rust that implants SPARQL and runs really fast because it can hit the delete rows directly This caused Claude Code for web to churn for over 12 hours. I checked in on its progress the next day and sent a single follow-up prompt when I noticed how many Rust crates it had built: Every folder in the crates/ directory needs a README Include a tutorial.md teaching users how to install the extension and how to run it in the SQLite CLI and then teaching them SPARQL in addition to how to use the SQLite extension Include a script with the tutorial for populating a SQLite database with useful and realistic ex...

6. ? The iPhone Duo
Source: Daring Fireball | Published: 2026-10-21T22:59:14Z
Link: https://daringfireball.net/2026/10/the_iphone_duo
It?s been a lot of fun trying the Duo out for a week, but it feels like I?ve gotten to use an extraordinarily polished prototype ? not a finished product that I?d want to buy and carry.

7. Ex-Apple Employee Fred Potter on HomeView
Source: Daring Fireball | Published: 2026-10-19T18:05:38Z
Link: https://www.linkedin.com/posts/frpotter_tonight-im-looking-back-through-the-photo-share-7515791565718454272-ue-R/
Fred Potter, on LinkedIn: So if you ever meet someone who tells you, ?At Apple, I?m the one who did this,? take it with a grain of salt. They were probably part of the team that made it happen, and that?s already something to be proud of. Sometimes, when the final product finally comes out, you can recognize a few of the personal touches you contributed along the way. And that, in itself, is immensely rewarding. Wishing HomeView every success! Potter?s LinkedIn bio lists his time at Apple as July 2021 through June 2024, and describes it only as ?Worked on HomeView?. (Via Christophe Laporte at iGeneration .) ?

8. Netflix Lays Off 6 Percent of Staff
Source: Daring Fireball | Published: 2026-10-19T16:32:06Z
Link: https://www.wsj.com/business/media/netflix-eliminates-about-6-of-staff-in-biggest-cuts-since-2022-0a2d8ec3?st=NtEg5v&reflink=desktopwebshare_permalink
Joe Flint and Jessica Toonkel, reporting for The Wall Street Journal last week: Netflix is cutting 6% of its staff, or roughly 1,000 positions globally, its biggest round of layoffs since 2022, as it struggles with slowing growth and customer engagement. Co-Chief Executives Greg Peters and Ted Sarandos said in an email to employees Wednesday morning that the bulk of the cuts would be in the streaming giant?s product, tech, legal and human-resources teams. The layoffs may have hit those teams (including some of the talent that created the excellent Duo support for Netflix?s iOS app), but Peters and Sarandos seem to know where the fundamental problem lies: Netflix has peaked and their content blows. Flint, in a follow-up report the next day, ? Netflix Replaces Content Chief as It Struggles to Engage Viewers ?: Netflix?s Chief Content Officer Bela Bajaria is leaving the company, as it struggles with slowing growth and falling customer engagement. Yours truly, back in August: ? Netflix Has Peaked ?. ?

9. Why didn?t we use Ro›Register›For›Apartment›Shutdown to clean up the unmarshalable delegate?
Source: The Old New Thing | Published: Wed, 21 Oct 2026 14:00:00 +0000
Link: https://devblogs.microsoft.com/oldnewthing/20261021-00/?p=112786/
Too many requirements, some of which bring us full circle. The post Why didn?t we use

Ro›Register›For›Apartment›Shutdown to clean up the unmarshalable delegate? appeared first on The Old New Thing .

10. Microspeak: Drain the slide, back-up slides
Source: The Old New Thing | Published: Tue, 20 Oct 2026 14:00:00 +0000
Link: https://devblogs.microsoft.com/oldnewthing/20261020-00/?p=112784/
PowerPoint presentation jargon. The post Microspeak: Drain the slide, back-up slides appeared first on The Old New Thing .

11. Can they write a function?
Source: Software and Tech stories from an Insider - iDiallo.com | Published: Wed, 21 Oct 2026 19:00:40 GMT
Link: https://idiallo.com/blog/can-they-write-a-function
For a software developer position, there isn't a trick to finding the best candidate. Your criteria do not determine how solid the candidates will be. Everyone is submitting 500 applications a month now, and those who automate the process submit thousands. So how do you hire a great candidate? Pick a few from the lot, ask them if they can write a function, have them do a live FizzBuzz test, then ask them to deploy a service from localhost to an actual public server. That's it. Hire them after that. As far as experience is concerned, they will learn on the job. If you think they don't know how to write tests or use a particular paradigm, they can ask ChatGPT and apply what it tells them a few times until they get familiar with it. People learn on the job . Nobody knows what the hell back pressure is until they encounter it in a particular service. Everything else is really just random. We insist on things like culture, but we have no way of measuring it. It's all so arbitrary. For example, early in my career I had an in-person interview where the head of HR brought me close to tears. She would make a joke, I would laugh, and while I was laughing she would stop and vigorously take n...

12. "No way to prevent this" say users of only language where this regularly happens
Source: Xe Iaso's blog | Published: Wed, 21 Oct 2026 00:00:00 GMT
Link: https://xeiaso.net/shitposts/no-way-to-prevent-this/memory-safety/CVE-2026-94300/
In the hours following the release of CVE-2026-94300 for the project BIND 9 named , site reliability workers and systems administrators scrambled to desperately rebuild and patch all their systems to fix memory corruption in named triggered by replaying captured GSS-TSIG-signed UDP messages while the negotiated TSIG key remains valid, potentially allowing remote code execution when combined with crafted queries to an attacker-controlled zone. This is due to the affected components being written in C, the only programming language where these vulnerabilities regularly happen. "This was a terrible tragedy, but sometimes these things just happen and there's nothing anyone can do to stop them," said programmer Queen Aniya Rippin, echoing statements expressed by hundreds of thousands of programmers who use the only language where 90% of the world's memory safety vulnerabilities have occurred in the last 50 years, and whose projects are 20 times more likely to have security vulnerabilities. "It's a shame, but what can we do? There really isn't anything we can do to prevent memory safety vulnerabilities from happening if the programmer doesn't want to write their code in a robust manner....

13. "No way to prevent this" say users of only language where this regularly happens
Source: Xe Iaso's blog | Published: Wed, 21 Oct 2026 00:00:00 GMT
Link: https://xeiaso.net/shitposts/no-way-to-prevent-this/memory-safety/CVE-2026-111813/
In the hours following the release of CVE-2026-111813 for Apache Traffic Server , site reliability workers and systems administrators scrambled to patch systems running its experimental magick plugin. In its default unsigned configuration, the plugin lets unauthenticated clients control arguments passed to ImageMagick convert, allowing anyone to execute whatever command they want on the server. The affected plugin is written in C++, whose users were relieved that this time the attacker did not even have to corrupt memory to tell the server what to do. "This was a terrible tragedy, but sometimes these things just happen and there's nothing anyone can do to stop them," said programmer Mr. Friedrich Frami, whose image

processing plugin accepted instructions from anyone who could construct a URL. "It’s a shame, but what can we do? There really isn’t any way to know whether a stranger on the internet should be allowed to choose command arguments for a program running on our server. We made signature verification optional, so we’ve already done everything we can." At press time, administrators installing versions 9.2.16, 10.1.5, or 10.2.1 to fix the issue were referring to themselves an...

14. "No way to prevent this" say users of only language where this regularly happens
Source: Xe Iaso’s blog | Published: Wed, 21 Oct 2026 00:00:00 GMT
Link: https://xeiaso.net/shitposts/no-way-to-prevent-this/memory-safety/CVE-2026-111497/
In the hours following the release of CVE-2026-111497 for the project Brotli , site reliability workers and systems administrators scrambled to desperately rebuild and patch all their systems to fix an out-of-bounds write in the Brotli decoder that permits remote code execution when processing malformed compressed streams. This is due to the affected components being written in C, the only programming language where these vulnerabilities regularly happen. "This was a terrible tragedy, but sometimes these things just happen and there’s nothing anyone can do to stop them," said programmer Dr. Lester Cremin, echoing statements expressed by hundreds of thousands of programmers who use the only language where 90% of the world’s memory safety vulnerabilities have occurred in the last 50 years, and whose projects are 20 times more likely to have security vulnerabilities. "It’s a shame, but what can we do? There really isn’t anything we can do to prevent memory safety vulnerabilities from happening if the programmer doesn’t want to write their code in a robust manner." At press time, users of the only programming language in the world where these vulnerabilities regularly happen once or t...

15. Backdoors, Incompetence, and Elliptic Curves
Source: John D. Cook | Published: Wed, 21 Oct 2026 15:16:51 +0000
Link: https://www.johndcook.com/blog/2026/10/21/emudhra/
The NIST elliptic curves have been in the news twice lately. A few days ago Anthropic posted a paper on the NIST curve seeds that I wrote about here. Now the curves are in the news again, this time over broken certificates. My post a few days ago was about the possibility that the NSA [?] The post Backdoors, Incompetence, and Elliptic Curves first appeared on John D. Cook .

16. Deliberate imperfection
Source: John D. Cook | Published: Wed, 21 Oct 2026 12:04:06 +0000
Link: https://www.johndcook.com/blog/2026/10/21/deliberate-imperfection/
I was watching a video by John Higgins this morning about the poem in Ecclesiastes 3, one of the most famous passages in the Bible. There is a time for everything, and a season for every activity under the heavens: a time to be born and a time to die, a time to plant and [?] The post Deliberate imperfection first appeared on John D. Cook .

17. Trust Stores Are Dependencies Too
Source: Andrew Nesbitt | Published: 2026-10-21T16:00:00+00:00
Link: https://nesbitt.io/2026/10/21/trust-stores-are-dependencies-too.html
eMudhra generated eight of its intermediate CA certificates incorrectly, so their private keys can be recovered from the certificates themselves. Firefox (OneCRL and CRLite) and Chrome (CRLSets) blocked the intermediates on 17 October, Apple on the 19th, and Microsoft on the 20th through Windows? automatic trust list updates. The disclosure page states that ?many other clients do not consume revocation information and require software updates?, and its fix table lists the packages that carry their own copy of the roots: certifi 2026.10.19 and pip 26.2.2 uv 0.13.4 and pixi 0.82.1 webpki-roots and webpki-root-certs 1.0.10, rustls-webpki 0.103.16, rustup 1.29.2 Node.js 22.23.4, 24.22.1 and 26.12.1 Go 1.27.3 and 1.26.10 Composer?s ca-bundle, Elixir?s castore 1.0.22, Perl?s Mozilla::CA 20261020 the curl CA bundle, NSS 3.131.1, and a row of Linux distributions the pip3 shipped with macOS, which uses ?its own outdated copy of the roots? Micha? Górny, who maintains a large part of Gentoo?s Python packaging, traced where certifi alone ends up . Gentoo?s certifi is patched to use the system store, so system Python

picks up the change when ca-certificates updates. Everywhere else needs its o...

18. No Need for Retirement When Utopia Is Around the Corner
Source: Jim Nielsen?s Blog | Published: Wed, 21 Oct 2026 19:00:00 GMT
Link: https://blog.jim-nielsen.com/2026/skip-retirement-for-utopia/
I?ve mentioned before my interest in the history and development of nuclear weapons . Currently, I?m reading The Doomsday Machine: Confessions of a Nuclear War Planner by Daniel Ellsberg (of Pentagon Papers renown). In the first chapter, Ellsberg talks about his time working at the RAND Corporation during the missile gap years when the U.S. thought it was falling behind the Soviet Union in nuclear capabilities. Many of his descriptions sound strikingly similar to the rhetoric coming out of places like Anthropic. For example, note the religious overtones of working at a corporation: I loved RAND, where I ended up spending ten years [...] Much, I imagined, like members of a religious order would, I shared with my colleagues a sense of brotherhood, living and working with others for a transcendent cause. They were insiders : burdened with the responsibility of knowledge others did not possess. precisely in my early missile-gap years at RAND and as a consultant in Washington, there was our sense of mission, the burden of believing we knew more about the dangers ahead, and what might be done about them, than did the generals in the Pentagon or SAC, or Congress or the public, or even th...

19. Pluralistic: Adversarial interoperability is a team sport (21 Oct 2026)
Source: Pluralistic: Daily links from Cory Doctorow | Published: Wed, 21 Oct 2026 20:05:21 +0000
Link: https://pluralistic.net/2026/10/21/brittle-individualism/
Today’s links Adversarial interoperability is a team sport: Vibe-coded jailbreaks are fun, but don’t solve the problem. Hey look at this: Delights to delectate. Object permanence: Labour Whip’s pro-Iraq war threats; LoC’s emulators; Kevin Mitnick plays CIA stooge; ICE: "The warrant is coming out of my balls"; WIPO’s secret trademark meeting; Linking isn’t libel (in Canada); Make: singing busts; Tory minister kills Turing’s Law; Trump hotels rebrand as "Scion". Upcoming appearances: Vancouver, Ottawa, Vienna, Kilkenny, Courtenay, Vancouver, Oxford, Sheffield, Virtual, Oxford, Montreal. Recent appearances: Where I’ve been. Latest books: You keep readin’ em, I’ll keep writin’ ’em. Upcoming books: Like I said, I’ll keep writin’ ’em. Colophon: All the rest. Adversarial interoperability is a team sport (permalink)
Enshittification is particularly galling because (in theory, at least), digital technology should be really hard to enshittify. That’s because the only digital computer we know how to build is the "Turing-complete, universal von Neumann machine," which is to say, a calculating engine capable of computing every valid program. In some deep, important, foundational sense, every c...

20. Going Somewhere
Source: Simone Salis | Published: Wed, 21 Oct 2026 16:14:51 GMT
Link: https://simone.org/somewhere/
Vicky, driving me home from O’Hare, got sixteen dollars for the best conversation I had in months. The last line is hers.

21. Rails is a JIT compiler
Source: Max Bernstein’s Blog | Published: Wed, 21 Oct 2026 00:00:00 +0000
Link: https://bernsteinbear.com/blog/rails-is-a-jit-compiler/?utm_source=rss
Originally published on Rails At Scale . The title was bait to get you to open this article.
But fear not! We will be generating code at run-time today. (See the PR for a sneak peek.) Sam popped into the JIT channel asking how we might optimize Rails enums in Roundhouse, motivated by the following code snippet: class Order ActiveRecord :: Base enum :status , { pending: 0 , paid: 1 , shipped: 2 , refunded: 3 } def shippable? paid? && ! refunded? end end In particular, there is a lot of dynamic behavior going on with the code generated by Rails enum and Sam wanted to know if inlining it all away in an (external-to-Rails) build step would help. That

didn?t sound right to me because I thought that: Rails got a lot better in recent years about removing these dynamic lookups in favor of creating and caching methods ZJIT should be able to handle dispatch to methods (generated or otherwise) just fine So I inquired and Sam presented to us the implementation of enum which contained this gem: value = 0 define_method (" #{ value_method_name } ?") { public_send (:" #{ name } _for_database") == value } Now fortunately, this is not the fully dynamic lookup I was worried about! No hashes, etc...

22. Objects, attributes, maps, oh my!
Source: Max Bernstein’s Blog | Published: Wed, 21 Oct 2026 00:00:00 +0000
Link: https://bernsteinbear.com/blog/object-shapes/?utm_source=rss
Or, IC UC we all C for ICs . In many dynamically typed programming languages, objects look like a big ol? mapping of names to values. The languages encourage this flexibility. Consider for example Python: class C : def __init__ (self): self . a = 1 self . b = 2 Or Ruby: class C def initialize @a = 1 @b = 2 end end Or JavaScript 1 : let obj = {}; obj . a = 1 ; obj . b = 2 ; This might encourage the VM implementor to model object attributes using a hash table. Hash tables, after all, are very good at mapping names to values. Here is, by way of example, a Python sketch of what this object model looks like. Because it is a sketch, it uses write_attr and read_attr instead of the much more common syntax that your programming language comes with. MISSING = object () class Instance : def __init__ (self): # TODO: the rest of your object system self . cls = ... self . _fields = {} def read_attr (self , fieldname): return self . _fields . get (fieldname , MISSING) def write_attr (self , fieldname , value): self . _fields [fieldname] = value obj = Instance () obj . write_attr ("a" , 1) obj . write_attr ("b" , 2) print (obj . read_attr ("a") + obj . read_attr ("b")) This h...